



PERFORMANCE WORK STATEMENT (PWS) DEPARTMENT OF VETERANS AFFAIRS

**Office of Information & Technology
Health Data Management (HDM)**

**Integrated eNotifications Service Pilot via Direct Secure Messaging
(DSM)**

**Date: April 27, 2026
VA-26-00049664**

PWS Version Number: 2.0

Contents

1.0	BACKGROUND.....	Error! Bookmark not defined.
2.0	APPLICABLE DOCUMENTS.....	3
3.0	SCOPE OF WORK.....	5
4.0	PERFORMANCE DETAILS.....	6
4.1	PERFORMANCE PERIOD	6
4.2	PLACE OF PERFORMANCE	6
4.3	TRAVEL.....	6
5.0	SPECIFIC TASKS AND DELIVERABLES.....	7
5.1	PROJECT MANAGEMENT.....	7
5.1.1	CONTRACTOR PROJECT MANAGEMENT PLAN....	Error! Bookmark not defined.
5.1.2	PRIVACY AND HIPAA TRAINING	Error! Bookmark not defined.
5.1.3	KICKOFF MEETING.....	7
5.1.4	REPORTING REQUIREMENTS	Error! Bookmark not defined.
5.2	ADMISSIONS, DISCHARGE AND TRANSFER (ADT) ELECTRONIC NOTIFICATION SERVICE.....	7
5.2.1	ADT SERVICE REQUIREMENTS.....	7
5.2.2	SAAS FEDRAMP REQUIREMENTS.....	Error! Bookmark not defined.
5.2.3	SECURE FILE TRANSFER PROTOCOL (SFTP)	11
5.2.4	MONITORING, TECHNICAL SUPPORT AND MAINTENANCE	14
5.3	OPTIONAL TASK 1 – ADDITIONAL PATIENTS	Error! Bookmark not defined.
6.0	GENERAL REQUIREMENTS.....	15
6.1	ENTERPRISE AND IT FRAMEWORK.....	15
6.1.1	VA TECHNICAL REFERENCE MODEL.....	15
6.1.2	ZERO TRUST – VA CRITICAL SECURITY CONTROLS.....	15
6.1.3	FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)	16
6.1.4	INTERNET PROTOCOL VERSION 6 (IPv6)	18
6.1.5	TRUSTED INTERNET CONNECTION (TIC).....	18
6.1.6	VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM).....	18
6.1.7	PROCESS ASSET LIBRARY (PAL).....	19
6.1.8	AUTHORITATIVE DATA SOURCES.....	19
6.1.9	SOCIAL SECURITY NUMBER (SSN) REDUCTION	20
6.1.10	SOFTWARE AND LICENSING REQUIREMENTS.....	20
6.2	SECURITY AND PRIVACY REQUIREMENTS.....	20
6.2.1	POSITION/TASK RISK DESIGNATION LEVEL(S)	21
6.2.2	CONTRACTOR PERSONNEL SECURITY REQUIREMENTS	21
6.3	METHOD AND DISTRIBUTION OF DELIVERABLES.....	23
6.4	PERFORMANCE METRICS	23
	ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED	25

ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE.....	30
---	----

1.0 BACKGROUND

The Department of Veterans Affairs (VA), Veterans Health Administration (VHA), Office of Mental Health and Suicide Prevention (OMHSP), in coordination with the Office of Information & Technology (OIT) Health Data Management portfolio is pursuing enhanced capabilities to support care coordination and suicide prevention efforts for Veterans receiving care in community settings. This effort aligns with legislative priorities including Elizabeth Dole 21st Century Veterans Healthcare and Benefits Improvement Act, which emphasizes improved care coordination, timely access to information, and enhanced support for Veterans at risk.

VHA has identified a gap in timely visibility into care events occurring outside of VA facilities, particularly for Veterans receiving treatment in community hospitals, emergency departments, and post-acute care settings. Without timely notification of these events, VA care teams may be delayed in coordinating follow-up care, which is especially critical for Veterans identified as high-risk. Improving awareness of these events is essential to enabling proactive outreach and prevention.

To address this gap, VA is exploring the use of electronic notification (eNotification) services that provide near real-time alerts for Admission, Discharge, and Transfer (ADT) events occurring in community settings. Market research conducted by VA indicates that no single vendor provides sufficient national coverage across all relevant care settings. As a result, a solution that leverages multiple notification networks is necessary to achieve targeted/adequate coverage and ensure comprehensive visibility into Veteran care events.

This pilot will support up to six (6) VA Medical Centers (VAMCs) and a defined population of Veterans identified as high-risk. VA will provide a Veteran attribution list, that will be updated periodically, to enable targeted notification delivery. Notifications will be transmitted via Direct Secure Messaging (DSM) infrastructure, through the Oracle Health's Health Information Service Provider (HISP), into VA Direct Secure Messaging (DSM) inboxes, leveraging existing infrastructure without requiring direct integration with VA clinical systems. The objective of the pilot is to assess the effectiveness, timeliness, and operational impact of eNotification services in improving care coordination and supporting suicide prevention efforts.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement, the Contractor shall comply with the following:

1. "Federal Information Security Modernization Act (FISMA) of 2014"

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

2. 36 C.F.R. Part 1194 "Information and Communication Technology Standards and Guidelines," as amended
3. Office of Management and Budget (OMB) Circular A-130, "Managing Federal Information as a Strategic Resource," July 28, 2016
4. 45 C.F.R Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 C.F.R. Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"); as amended
5. VA Directive 6500, "VA Cybersecurity Program," February 24, 2021 (see VA NOTICE 24-18, dated September 27, 2024, "Update to VA Directive 6500 Cybersecurity Program", and VA Notice 25-07, dated 3/18/25, "Amending VA Directive 6500 to incorporate M-24-15")
6. VA Handbook 6500, "Risk Management Framework for VA Information Systems VA Information Security Program," February 24, 2021 (see VA Notice 25-01, dated October 15, 2024, "Update to VA Handbook 6500 Risk Management Framework for VA Information Systems VA Information Security Program", and VA Notice 25-06, dated 3/18/25, "Amending VA Directive 6500 to incorporate M-24-15")
7. VA Handbook 6500.2, "Management of Breaches Involving Sensitive Personal Information (SPI)," June 30, 2023
8. VA Handbook 6500.6, "Contract Security," March 12, 2010 (see VA Notice 24-12, dated April 22, 2024, "Update to VA Handbook 6500.6, Contract Security, Appendix C VA Information and Information System Security/Privacy Language For Inclusion Into Contracts, As Appropriate")
9. VA Handbook 6500.8, "Information System Contingency Planning," March 25, 2025
10. OIT Process Asset Library (PAL), OIT Process Asset Library.
11. One-VA Technical Reference Model (TRM) (reference at <https://www.va.gov/trm/TRMHomePage.aspx>)
12. VA Directive 6508, "Implementation of Privacy Threshold Analysis and Privacy Impact Assessment," October 15, 2014
13. VA Directive 6510, "VA Identity, Credential and Access Management," September 3, 2024
14. VA Handbook 6510, "VA Identity, Credential and Access Management," September 27, 2024
15. VA Directive and Handbook 6513, "Secure External Connections," October 12, 2017
16. VA Directive 6300, "Records and Information Management," September 21, 2018
17. VA Handbook, 6300.1, "Records Management Procedures," March 24, 2010
18. NIST SP 800-37 Rev 2, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy," December 2018
19. NIST SP 800-53 Rev. 5, "Security and Privacy Controls for Federal Information Systems and Organizations," September 23, 2020 (includes updates as of 12/10/2020)

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

20. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
21. Social Security Number (SSN) Fraud Prevention Act of 2017
22. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018
23. Executive Order 14028, “Executive Order on Improving the Nation's Cybersecurity,” May 12, 2021, <https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2025/01/16/executive-order-on-strengthening-and-promoting-innovation-in-the-nations-cybersecurity/>
24. OMB Memorandum M-22-09, “Moving the U.S. Government Toward Zero Trust Cybersecurity Principles”, January 26, 2022, <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>.
25. CISA BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks.” Cybersecurity & Infrastructure Security Agency (CISA), BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks | CISA
26. Health Level 7 (HL7) version 2.x Messaging Standard, Health Level Seven International <https://www.hl7.org/implement/standards/index.cfm?ref=nav>
27. Direct Project, Applicability Statement for Secure Health Transport <https://directtrust.org/standards/the-direct-standard/versions>
28. DirectTrust, Security and Trust Framework <https://accreditation.directtrust.org/>
29. Federal Risk and Authorization Management Program (FedRAMP), Security Assessment Framework <https://www.fedramp.gov/frameworks/>
30. Federal Risk and Authorization Management Program (FedRAMP), Baseline Security Controls <https://fedramp.gov/baselines>
31. VA Enterprise Cloud (VA EC), Cloud Computing Guidance <https://www.oit.va.gov/services/cloud>

3.0 SCOPE OF WORK

The Contractor shall provide and implement an Admissions, Discharge, and Transfer (ADT) eNotifications Software as a Service (SaaS) utilizing multiple existing provider networks already in place to support a VA-defined population of Veterans identified as at-risk across up to six (6) VA Medical Center (VAMCs). The Contractor shall support a VA-defined population of up to approximately 82,000 patients, with attribution data provided and maintained by VA and updated on a quarterly basis. The Contractor shall provide implementation support including configuration, testing, and deployment of the SaaS solution and enable filtering of notifications based on VA-defined criteria, including Veteran/patient association with a home VAMC.

The Contractor shall support the ingestion, processing, and delivery of real-time ADT eNotifications associated with the VA-defined patient population and relevant treatment-related events. The Contractor shall support the secure transmission of eNotifications, using Direct Secure Messaging through VA-approved Health Information Service Provider (HISP) or other VA-approved mechanisms to securely exchange Veteran/patient attribution data with VA. The Contractor shall support coordination

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

across multiple provider networks to maximize coverage of relevant community care encounters and provide ongoing technical support and systems maintenance throughout the period of performance. The Contractor shall support VA security and privacy requirements, including provision of documentation and activities necessary to achieve and maintain an appropriate security authorization in accordance with VA policies and procedures. This effort is a pilot and shall support evaluation of notifications coverage, timeliness, and effectiveness to inform potential future expansion.

4.0 PERFORMANCE DETAILS

4.1 PERFORMANCE PERIOD

The Period of Performance shall be 12 months from the date of award with one optional task.

There are 11 Federal holidays set by law (USC Title 5 Section 6103) that VA follows:

Under current definitions, five are set by date:

New Year's Day	January 1
Juneteenth	June 19
Independence Day	July 4
Veterans Day	November 11
Christmas Day	December 25

If any of the above falls on a Saturday, then Friday shall be observed as a holiday. Similarly, if one falls on a Sunday, then Monday shall be observed as a holiday.

The other six are set by a day of the week and month:

Martin Luther King's Birthday	Third Monday in January
Washington's Birthday	Third Monday in February
Memorial Day	Last Monday in May
Labor Day	First Monday in September
Columbus Day	Second Monday in October
Thanksgiving	Fourth Thursday in November

4.2 PLACE OF PERFORMANCE

Tasks under this PWS shall be performed at Contractor facilities. The Contractor shall identify the Contractor's place of performance in their proposal submission.

4.3 TRAVEL

The Government does not anticipate any travel under this effort to perform the tasks associated with the effort. Any required meetings will be held remotely/virtually.

5.0 SPECIFIC TASKS AND DELIVERABLES

The Contractor shall provide and perform the following:

5.1 PROJECT MANAGEMENT

5.1.1 KICKOFF MEETING

The Contractor shall conduct a kickoff meeting within five business days after award. The Contractor shall present, for review and approval by the Government, the details of the intended approach, work plan, and implementation schedule. The Contractor shall provide an agenda at least two business days prior to the kickoff meeting and minutes within two business days following the meeting. The Contractor shall invite the Contracting Officer (CO), Contract Specialist (CS), Contracting Officer's Representative (COR), VA Program Manager and others to be identified post-award. Subsequent weekly meetings will be held until the service is 'turned on' then bi-weekly three weeks following enablement.

Deliverables:

- A. Kickoff Meeting Agenda
- B. Kickoff Meeting Minutes

5.2 ADMISSIONS, DISCHARGE AND TRANSFER (ADT) ELECTRONIC NOTIFICATION SERVICE

5.2.1 ADT SERVICE REQUIREMENTS

The Contractor shall provide and implement a SaaS solution for Admissions, Discharge and Transfer (ADT) eNotifications. The eNotification SaaS shall include functionalities related to admissions, discharges, transfers, real-time alerts, and data synchronization. The eNotification SaaS shall provide real-time notifications to the patient's respective VAMC ensuring seamless data exchange and communication between the different healthcare entities. This eNotification SaaS shall also include the ability to set up rules and filters to manage the flow of data and ensure that only relevant notifications are sent.

This is a pilot program that includes up to six (6) VAMC's- Charles George VA Medical Center (Asheville, NC), Columbus VA Health Care System, West Texas VA Health Care System (Big Spring, TX), Texas Valley Coastal Bend Health Care System (Harlingen,

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

TX), Jesse Brown VA Medical Center (Chicago, IL), Northern Arizona VA Health Care System (Prescott, AZ) – and a VA-defined Veteran population of up to approximately 82,000 patients (NTE 82K). The Contractor shall provide automated notifications for events associated with the VA-defined patient population, including but not limited to emergency department visits, inpatient admissions, discharges, and transitions of care.

On a quarterly basis or as needed, VA COR will securely provide a Patient Roster (e.g. spreadsheet) for a selected group of Veterans from each of the above named VAMC's. The Patient Roster shall include Identifying information, home VAMC assignment, and Direct Messaging addresses associated with the VA designated endpoints. VA retains full ownership of all data, including data provided in the Patient Roster and any data generated through the use of the eNotification SaaS.

The Contractor shall ingest and maintain VA-provided Patient Roster within the SaaS solution and utilize it to perform patient matching and attribution against incoming notification data using industry standard matching techniques. The Contractor shall apply VA-defined filtering criteria to ensure that only notifications relevance to the authorized veteran population and defined use cases are transmitted. The Contractor shall ensure that notifications are formatted in a consistent and usable manner to support VA operational workflows. The Contractor shall not transmit notifications unrelated to the VA defines patient cohort or outside the defined event criteria. The Contractor shall support ingestion and coordination of notification data from multiple provider networks to maximize coverage of relevant healthcare encounters for patients at risk. The Contractor shall perform deduplication of notifications across all data sources and provider networks prior to delivery to VA designated endpoints.

The Contractor shall support the secure transmission of eNotifications, using Direct Secure Messaging through VA-approved HISP services to VA's Direct Messaging System (DSM). The Contractor shall ensure that notification volume, frequency, and formatting are managed to prevent overload of the VA DSM endpoints.

The Contractor shall support the secure exchange of Patient Roster data using VA-approved mechanisms, including DSM or Secured File Transfer Protocol (SFTP), as directed by VA based on data size and operational considerations. The Contractor shall ensure all data exchanges comply with applicable privacy and security requirements, including HIPAA, to include encryption of Data-in-Transit (DIT) and Data-at-Rest (DAR) and maintain audit logs of the data access and modification.

The Contractor shall configure notification rules, filtering, and routing based on VA-defined criteria and VAMC-specific requirements and shall update configurations at the request of the VA Project Manager (PM).

The Contractor shall provide an Implementation Plan. This plan shall include detailed requirements analysis, identification of required data elements, a plan and timeline for deployment, the verification plan for successful deployment, documented Incident Response Plan (IRP) in the event of a data breach, and procedures for secure data

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

retention and disposal. The Contractor shall be responsible for the processing and delivery of notifications to VA-designated endpoints and for ensuring successful transmission to those endpoints in accordance with the requirements of this PWS.

Deliverable:

- A. ADT Notification Service supporting up to 82,000 patients across participating VAMCs
- B. Implementation Plan

5.2.2 SAAS SECURITY AND AUTHORIZATION REQUIREMENTS

The Contractor shall demonstrate, at time of award, existing security authorization or comparable evidence of compliance with Federal and VA security requirements sufficient to support deployment within the period of performance. Acceptable evidence may include an active FedRAMP authorization, an VA Authority to Operate (ATO), or equivalent security documentation and controls demonstrating alignment with VA security requirements. Solutions that require substantial development of security authorization artifacts or initiation of a new authorization process after award may be deemed unacceptable.

5.2.2.1 If the solution is not FedRAMP authorized:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA).
2. The Contractor shall comply with FedRAMP requirements **HIGH** as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The Contractor shall provide a SaaS product as defined by the following criteria:
Software as a Service (SaaS) is an application delivery model in which the application is hosted on a cloud infrastructure outside the security boundary of VA and is provided to the Cloud Service Customer (CSC) over the internet. The CSC uses the SaaS offering via a thin-client interface, such as a web-browser or a program interface. The CSC subscribes to the SaaS offering and is only responsible for minor in-app customizations. The Cloud Service Provider (CSP) offering the application is responsible for management of the application, safeguarding of data stored or processed by the application, and all elements of the underlying infrastructure. Additionally, the CSP is responsible for all on-going compliance. In order to qualify as SaaS for use at VA, and to align with Federal Risk and Authorization Management Program (FedRAMP) requirements, the hosting for the offering must conform to the NIST 800-145 definition of Cloud Computing and thus contain following key characteristics:
 - *On-Demand Self-Service*: The CSP fully automates the provisioning of both the customer interface and the underlying cloud components of the SaaS offering. In

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

- some cases, to the CSP may provision internal resources manually, while providing the CSC an automated interface to request and track the service.
- *Broad Network Access*: The SaaS capabilities are available over the internet or over a network that is available from all access points the CSC requires. The SaaS offering is accessible through common platforms (e.g., mobile phones, tablets, laptops, and workstations).
 - *Resource Pooling*: The computing infrastructure supporting the SaaS offering is shared among more than one CSC using a multi-tenant model, and resources are dynamically assigned depending on customer demand.
 - *Rapid Elasticity*: Computing capabilities are automatically provisioned and released in a manner that scales with customer demand. In some cases, the scaling of resources may not be fully automated, but it should be fast enough to support the needs of the CSC, which the CSC would have to define.
 - *Measured Service*: Resource usage, such as storage, processing, bandwidth, and user activity are measured and reported on in a manner that is relevant to the SaaS offering.
4. Following guidance from the Federal CIO, VA will utilize existing JAB ATO or agency ATO issued by another agency as a starting point for FedRAMP requirements. If neither of those exist, VA will sponsor The Cloud Service Provider for a FedRAMP Authorization. VA will be using the FedRAMP baselines as a starting point, since they are specifically tailored for cloud services.
 5. The Contractor shall, where applicable, assist with the VA ATO Process to help achieve agency authorization of the cloud service or migrated application at the impact level required by VA to utilize the product. For this solution the required impact level is: **HIGH**
 6. The Contractor shall comply with FedRAMP requirements surrounding data location within the Continental United States. FedRAMP specifies data location requirements in the High Baseline as part of control SA-9 (5); however, FedRAMP does not provide or specify data location requirements for other baselines.
 7. The Contractor shall complete a FedRAMP System Security Plan (SSP) and supporting documentation including required attachments within 94 calendar days after contract award.
 8. The Contractor shall work with a VA DTC Subject Matter Expert to develop a specific system boundary diagram including any integration and connectivity components for VA use. This will be known as the VA Implementation Diagram (VAID) and will demonstrate the proposed implementation of this system at VA. The Contractor shall complete this deliverable with VA within 10 calendar days of contract award.
 9. The Contractor shall complete a Third-Party Assessment Organization (3PAO) Security Assessment Plan (SAP) within 113 calendar days after contract award.
 10. The Contractor shall complete a 3PAO Security Assessment Report (SAR) within 113 calendar days after the SSP is accepted by VA.
 11. The Contractor shall work with VA Subject Matter Experts to test the validity of the Incident Response Plan (IRP) and ensure proper troubleshooting of issues that may arise. This should be completed within 30 calendar days of the SSP being delivered.

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

12. The Contractor shall afford VA access to the Contractor's and Cloud Service Provider's (CSP) facilities, installations, technical capabilities, operations, documentation, records, and databases.
13. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall immediately bring the situation to the attention of the other party in accordance with Addendum B, VA Information, and Information System Security/Privacy Language.
14. The Contractor shall comply with data management requirements.
15. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
16. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy Guide found on the FedRAMP website.
17. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
18. The Contractor shall provide continuous monitoring activities including, but not limited to scans, security artifacts, and monthly Plan of Action and Milestones (POAM) reports as outlined by VA and FedRAMP requirements.
19. The Contractor shall provide a monthly inventory report of VA sites currently utilizing the cloud product post ATO award. The inventory report will include the number of licenses being utilized and the specific VA site.

Deliverables:

- A. FedRAMP System Security Plan (SSP) and required Attachments
- B. VA Implementation Diagram
- C. 3PAO Security Assessment Plan (SAP)
- D. 3PAO Security Assessment Report (SAR)
- E. Plan of Action and Milestones Monthly Reports.
- F. Monthly Inventory Report

5.2.2.2 IF THE SOLUTION IS FedRAMP AUTHORIZED BUT NOT VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA)
2. The Contractor shall remain in compliance with FedRAMP requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The system must be FedRAMP Authorized at no less than the **HIGH**
4. The Contractor shall, where applicable, assist with the VA ATO Process to help achieve agency authorization of the cloud service or migrated application.
5. The Contractor shall provide confirmation of the completion of its FedRAMP System Security Plan (SSP) and supporting documentation by providing, to the VA PM, COR, and DTC, its repository ID number and associated link for VA to

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

download the SSP and all required artifacts within five calendar days of contract award.

6. The Contractor shall work with a VA DTC Subject Matter Expert to develop and provide a VA specific system boundary diagram including any integration and connectivity components for VA use. This will be known as the VA Implementation Diagram (VAID) and will demonstrate the proposed implementation of this system at VA.
7. The Contractor shall provide the results of their most recent Third-Party Assessment Organization (3PAO) Security Assessment Plan (SAP).
8. The Contractor shall complete a 3PAO Security Assessment Report (SAR).
9. The Contractor shall provide VA with the most recent monthly scans for the production environment within the authorization boundary and their scan upload schedule for FedRAMP within 30 calendar days of contract award.
10. The Contractor shall provide their availability to participate in monthly continuous monitoring meetings to be scheduled following successful VA ATO within 30 calendar days of contract award.
11. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language.
12. The Contractor shall comply with FedRAMP data management requirements.
13. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
14. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy.
15. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
16. The Contractor shall provide continuous monitoring activities including, but not limited to scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by VA and FedRAMP requirements.
17. The Contractor shall provide a Monthly VA License Report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

- A. VA Implementation Diagram
- B. 3PAO Security Assessment Plan (SAP)
- C. 3PAO Security Assessment Report (SAR)
- D. Plan of Action and Milestones Reports
- E. Monthly VA License Report

5.2.2.3 IF THE SOLUTION IS FedRAMP AUTHORIZED AND VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA) and have a current VA authorization.
2. The Contractor shall remain in compliance with FedRAMP requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The FedRAMP Authorization level and existing VA ATO should be no less than the level required for this use case which has been defined as **HIGH**
4. The Contractor shall, where applicable, assist with the VA ATO Sustainment Process to help maintain health and quality of agency authorization of the cloud service or migrated application.
5. The Contractor shall exclusively provide subscription licenses to FedRAMP authorized and VA authorized environments.
6. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language. VA Privacy and Security deliverables as directed by the VA System owner.
7. The Contractor shall comply with FedRAMP data management requirements.
8. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
9. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy Guide found on the FedRAMP Website.
10. The Contractor shall provide continuous monitoring activities including, but not limited to, scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by FedRAMP requirements.
11. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
12. The Contractor shall provide a Monthly VA License report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

- A. Continuous Monitoring Monthly Scans
- B. Plan of Action and Milestones Reports.
- C. Monthly VA License Report

5.2.3 SECURE FILE TRANSFER PROTOCOL (SFTP)

The Contractor shall provide Secure File Transfer Protocol (SFTP) and support other VA approved secure data exchange mechanisms, including Direct Secure Messaging (DSM), for sharing of the patient roster and securely exchanging patient information between the VA and other entities, as directed by VA. This process ensures that sensitive data is transferred in a secure, encrypted manner, minimizing the risk of data breaches or unauthorized access.

All secure data exchange mechanisms utilized under this contract for the exchange of VA information shall employ strong encryption standards (e.g., AES-256), for both data in transit and at rest, in compliance with all regulations and standards, such as HIPAA, VA data security guidelines, and latest Federal Information Processing Standards (FIPS) 140-3, detailed in Section 2.0 of this PWS. The solution shall maintain comprehensive audit trails logging all file transfer activities, including user access to VA data, data transmission, and any modifications, as applicable to the exchange method.

The SFTP service must maintain availability of 99.9% uptime to ensure continuous data exchange and be compatible with existing VA systems and workflows. The Contractor shall coordinate with VA to establish, test, validate, and maintain secure data exchange capabilities prior to operational use.

Deliverable:

1. Data Exchange Validation Confirmation

5.2.4 MONITORING, TECHNICAL SUPPORT AND MAINTENANCE

The Contractor shall provide ongoing monitoring, technical support and maintenance for the ADT eNotification Service to ensure reliable and effective operation.

The Contractor shall regularly monitor the performance of the ADT eNotification service to ensure it meets the needs of the VAMCs and identifying any areas for improvement. Status and recommendations shall be included in the Monthly Report from Section 5.1.4 of this PWS.

The Contractor shall track and provide metrics of performance in an ADT System Metrics Report and shall report metrics related to messages sent to VA by community provider, message type, and VAMC location. The Contractor shall also track and report on message delivery status, including successful transmissions, delays, and failures, as well as overall system performance and availability. The Contractor shall also provide metrics related to the effectiveness of filtering and deduplication processes, including identification of duplicate messages prevented and filtering outcomes based on VA-defined criteria.

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

This report shall be in a spreadsheet format or similar existing reports formats and shall be filterable with the following criteria:

- Number of messages sent to VA by VAMC (including time/date, patient identifier)
- Number of messages sent by message type (i.e., admission, discharge) with time/date
- Messages sent to VAMC by partner name/domain name
- Message delivery status (e.g. successful, delayed, failed)

All metrics shall include a summary and detailed information per patient (e.g., VAMC, partner name, event type, and timestamp). This report shall be delivered weekly for the first 90 days after implementation has been initiated with the option to transition to biweekly or monthly thereafter, as determined by VA. If patient information is included in the report, the report will be shared using VA-approved secure data exchange mechanisms.

The Contractor shall provide technical support and maintenance to the VAMC's and the PM. Any technical issues or interruptions in service reported by the VA PM shall be acknowledged within 1 hour and resolved in accordance with mutually agreed-upon service levels based on severity. The Contractor shall notify VA of any system outages, degradation in performance, or data exchange issues that may impact operations.

The Contractor shall also perform regular maintenance including software updates, patches, and security updates, to ensure continued performance and compliance. All maintenance performed and technical issues shall be detailed in the Monthly Report from Section 5.1.4 of this PWS.

Deliverables

1. ADT System Metrics Report

6.0 GENERAL REQUIREMENTS

6.1 ENTERPRISE AND IT FRAMEWORK

6.1.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all

necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

ALT. The Contractor shall ensure that any components or technologies that interface directly with VA systems or are deployed within the VA network environment comply with VA OIT Technical Reference Model (VA TRM), as applicable. The Contractor shall provide information, as requested by VA, to support review of technologies interacting with VA systems.

6.1.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

The Contractor shall support VA Zero Trust and security requirements as applicable to systems that process, store, or transmit VA data. For any components that directly connect to or operate within the VA network environment, the Contractor shall comply with applicable VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls."

For externally hosted SaaS solutions, the Contractor shall implement security controls and practices that provide equivalent protection of VA data and support VA security requirements for external connections and data exchanges. The Contractor shall cooperate with VA to demonstrate implementation of applicable security controls as required for authorization and ongoing operation.

6.1.3 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

The Contractor shall ensure Commercial Off-The-Shelf (COTS) product(s), software configuration and customization, and/or new software are Personal Identity Verification (PIV) card-enabled by accepting HSPD-12 PIV credentials using VA Enterprise Architecture (EA), and VA Identity and Access Management (IAM) approved Enterprise Technology Guidelines (ETG). The Contractor shall ensure all Contractor delivered applications and systems comply with the VA Identity, Credential, and Access Management policies and guidelines set forth in Executive Order 14028, VA Handbook 6510 VA Identity and Access Management, VA Handbook 0735 Homeland Security Presidential Directive 12 (HSPD-12) Program, CISA Binding Operational Directive 23-01, and align with the Federal Identity, Credential, and Access Management Roadmap and Implementation Guidance v2.0.

The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63-3, VA Handbook 6500, and VA IAM enterprise requirements for direct, assertion-based authentication, and/or trust based authentication, as determined by the ETGs. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV card and/or Common Access Card (CAC), as determined by the business need.

The Contractor shall ensure all Contractor delivered applications and systems conform to the specific Identity and Access Management PIV requirements set forth in the Office of Management and Budget (OMB) Memoranda M-05-24, M-19-17, M-22-09, and NIST Federal Information Processing Standard (FIPS) 201-3. Contractor delivered applications and systems shall be on the FIPS 201 Approved Product List (APL). If the Contractor delivered application and system is not on the APL, the Contractor shall be responsible for taking the application and system through the FIPS 201 Evaluation Program.

The Contractor shall ensure all Contractor delivered applications and systems support:

1. Automated provisioning and are able to use enterprise provisioning service.
2. Interfacing with VA's Master Person Index (MPI) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
3. The VA defined unique identity (Secure Identifier [SEC ID] / Integrated Control Number [ICN]).
4. Multiple authenticators for a given identity and authenticators at every Authenticator Assurance Level (AAL) appropriate for the solution.
5. Identity proofing for each Identity Assurance Level (IAL) appropriate for the solution.
6. Federation for each Federation Assurance Level (FAL) appropriate for the solution, if applicable.
7. Two-factor authentication (2FA) through an applicable Technology Guideline as outlined in VA ETG.

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

8. A Security Assertion Markup Language (SAML) implementation if the solution relies on assertion-based authentication. Additional assertion implementations, besides the required SAML assertion, may be provided as long as they are compliant with NIST SP 800-63-3 guidelines.
9. Authentication/account binding based on trusted Hypertext Transfer Protocol (HTTP) headers if the solution relies on Trust based authentication.
10. Role Based Access Control.
11. Auditing and reporting capabilities.
12. Compliance with VIEWS 00155984, PIV Logical Access Policy Clarification <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>.

The required Assurance Levels for this specific effort are Identity Assurance Level 3, Authenticator Assurance Level 3, and Federation Assurance Level 3.

6.1.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contactor Solution shall be capable of supporting applicable Internet Protocol Version 6 (IPv6) requirements in alignment with Office of Management and Budget (OMB) memorandum M-21-07 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>) and related Federal guidance, including the NIST USGv6 program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>) as well as NIST Special Publication 500-267B Revision 1 (<https://doi.org/10.6028/NIST.SP.500-267Br1>) and NIST SP 800-119 “Guidelines for the Secure Deployment of IPv6” (<https://doi.org/10.6028/NIST.SP.800-119>). For any Contractor delivered applications interfaces or services that directly connect or are accessed through VA network environments, this solution shall not preclude future operation in IPv6-only or dual stack IPv6/IPv4 environments, as directed by VA. For externally hosted SAS components, IPv6 capability shall be supported for applicable public-facing access points and integrated interfaces when required for VA implementation. The Contractor shall provide information upon request regarding the solution’s IPv6 readiness and any dependencies necessary to support future VA transition planning.

6.1.5 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative” (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 “Secure External Connections”, and shall comply with the TIC 3.0 Core Guidance Documents as applicable to the solution architecture and external connectivity model. The Contractor shall cooperate with VA in documenting and implementing secure external connection patterns necessary to support the service.

6.1.6 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)

The Contractor shall support VA governance, oversight, reporting, and delivery activities in accordance with the Veteran-Focused Integration Process (VIP) Guide and applicable Product Line Management practices including <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>. The Contractor shall provide timely information by VA related to schedule, risk, dependencies, milestones, deliverables, and operational readiness to support VA governance and reporting requirements. The Contractor shall coordinate with VA product line leadership, program management, and other designated stakeholders to support successful planning, implementation, and sustainment of the service.

6.1.7 PROCESS ASSET LIBRARY (PAL)

The Contractor shall perform their duties consistent with the processes defined in the OIT Process Asset Library (PAL). The PAL includes a spectrum of OIT functions and activities, such as project management, operations, service delivery, communications, acquisition, and resource management. PAL serves as an authoritative and informative repository of searchable processes, activities or tasks, roles, artifacts, tools and applicable standards and guides to assist the OIT workforce, Government and Contractor personnel. OIT utilizes PAL processes to ensure compliance with policies and regulations and to meet VA quality standards. The PAL includes the contractor onboarding process consistent with Section 6.2.2 and can be found at [process CONB ext.docx \(live.com\)](#). The main PAL can be accessed at www.va.gov/process.

6.1.8 AUTHORITATIVE DATA SOURCES

The VA Enterprise Architecture Repository (VEAR) is one component within the overall EA that establishes the common framework for data taxonomy for describing the data architecture used to develop, operate, and maintain enterprise applications. The Contractor shall comply with the department's Authoritative Data Source (ADS) requirement that VA systems, services, and processes throughout the enterprise shall access VA data solely through official VA ADSs where applicable, see below. The Information Classes which compose each ADS are located in the VEAR, in the Data & Information domain. The Contractor shall ensure that all delivered applications and system solutions support:

1. Interfacing with VA's Master Person Index (MPI) (formerly the Master Veteran Index (MVI)) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

2. Interfacing with Capital Asset Inventory (CAI) to conduct real property record management actions, if the solution relies on real property records data. CAI is the authoritative source for VA real property record management data.
3. Interfacing with electronic Contract Management System (eCMS) for access to contract, contract line item, purchase requisition, offering vendor, and solicitation information above the micro-purchase threshold, if the solution relies on procurement data. ECMS is the authoritative source for VA procurement actions data.
4. Interfacing with HRSmart Human Resources Information System to conduct personnel action processing, on-boarding, benefits management, and compensation management, if the solution relies on personnel data. HRSmart is the authoritative source for VA personnel information data.
5. Interfacing with VA Profile to access personal contact information, if the solution relies on VA Veteran personal contact information data. VA Profile is the authoritative source for VA Veteran Personal Contact Data.
6. Interfacing with VA/Department of Defense (DoD) Identity Repository (VADIR) for determining eligibility for VA benefits under Title 38, if the solution relies on qualifying active duty military service data. VADIR is the authoritative source for qualifying active duty military service in VA.
7. Interfacing with VA Systems Inventory (VASI) to access VA systems information, if the solution relies on VA system information. VASI is the authoritative source for VA Information Technology systems.
8. Interfacing with Enterprise Mission Assurance Support Service (eMASS) to access the Authority to Operate (ATO) status of all VA Information Systems. eMASS contains the official Authority to Operate (ATO) status of all VA Information Systems.

6.1.9 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the ICN in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA MPI for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

6.1.10 SOFTWARE AND LICENSING REQUIREMENTS

The Contractor shall be responsible for the provision of all software licenses and any associated licensing maintenance required for any development, delivery, integration, operation, and/or maintenance associated with its proposed application(s), software products, software solution, and/or system including, but not limited to, any and all application(s), software and/or software products that comprise, are a part of, or integrate with the Contractor's proposed application(s), software products, software solution, and/or system for the life of any resulting contract.

6.2 SECURITY AND PRIVACY REQUIREMENTS

6.2.1 POSITION/TASK RISK DESIGNATION LEVEL(S)

In accordance with VA Handbook 0710, Personnel Security and Suitability Program, the position sensitivity and the level of background investigation commensurate with the required level of access for the following tasks within the PWS are:

Position Sensitivity and Background Investigation Requirements by Task

Task Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
5.0	☒	☐	☐
5.1	☒	☐	☐
5.2	☒	☐	☐
5.3	☒	☐	☐

The Tasks identified above and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

6.2.2 CONTRACTOR PERSONNEL SECURITY REQUIREMENTS

Contractor Responsibilities:

- The Contractor shall prescreen all personnel requiring access to the computer systems to ensure they maintain the appropriate Background Investigation, and are able to read, write, speak, and understand the English language.
- Within 3 business days after award, the Contractor shall provide a roster of Contractor and Subcontractor employees to the COR to begin their

background investigations in accordance with the PAL template artifact. The Contractor Staff Roster shall contain the Contractor's Full Name, Date of Birth, Place of Birth, individual background investigation level requirement (based upon Section 6.2 Tasks), etc. The Contractor shall submit full Social Security Numbers either within the Contractor Staff Roster or under separate cover to the COR. The Contractor Staff Roster shall be updated and provided to VA within 1 day of any changes in employee status, training certification completion status, Background Investigation level status, additions/removal of employees, etc. throughout the Period of Performance. The Contractor Staff Roster shall remain a historical document indicating all past information and the Contractor shall indicate in the Comment field, employees no longer supporting this contract. The preferred method to send the Contractor Staff Roster or Social Security Number is by encrypted e-mail. If unable to send encrypted e-mail, other methods which comply with FIPS 140-2 (or its successor) are to encrypt the file, use a secure fax, or use a traceable mail service. (Note that by September 22, 2026, all FIPS 140-2 certificate validations will be placed on the Historical List. See FIPS Transition Effort Timeline for more details: <https://csrc.nist.gov/projects/fips-140-3-transition-effort#schedule>)

- c. The Contractor should coordinate with the location of the nearest VA fingerprinting office through the COR. Only electronic fingerprints are authorized. The Contractor shall bring their completed Security and Investigations Center (SIC) Fingerprint request form with them (see paragraph d.4. below) when getting fingerprints taken.
- d. The Contractor shall ensure the following required forms are submitted to the COR within 5 days after contract award:
 - 1) Optional Form 306
 - 2) Self-Certification of Continuous Service
 - 3) VA Form 0710
 - 4) Completed SIC Fingerprint Request Form
- e. The Contractor personnel shall submit all required information related to their background investigations (completion of the investigation documents (SF85, SF85P, or SF 86) utilizing the Office of Personnel Management's (OPM) Electronic Questionnaire for Investigations Processing (e-QIP) after receiving an email notification from the SIC.
- f. The Contractor employee shall certify and release the e-QIP document, print, and sign the signature pages, and send them encrypted to the COR for electronic submission to the SIC. These documents shall be submitted to the COR within 3 business days of receipt of the e-QIP notification email. (Note: OPM is moving towards a "click to sign" process. If click to sign is used, the Contractor employee should notify the COR within 3 business days that documents were signed via e-QIP).
- g. The Contractor shall be responsible for the actions of all personnel provided to work for VA under this contract. In the event that damages arise from work performed by Contractor provided personnel, under the auspices of this

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

contract, the Contractor shall be responsible for all resources necessary to remedy the incident.

- h. A Contractor may be granted unescorted access to VA facilities and/or access to VA Information Technology resources (network and/or protected data) with a favorably adjudicated Special Agreement Check (SAC), completed training delineated in VA Handbook 6500.6 (Appendix C, Section 4), signed "Contractor Rules of Behavior", and with a valid, operational Personal Identity Verification (PIV) credential for PIV-only logical access to VA's network. A PIV card credential can be issued once your SAC has been favorably adjudicated and your background investigation has been scheduled by OPM. However, the Contractor will be responsible for the actions of the Contractor personnel they provide to perform work for VA. The investigative history for Contractor personnel working under this contract must be maintained in the database of OPM.
- i. The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the contract.
- j. Failure to comply with the Contractor personnel security investigative requirements may result in loss of physical and/or logical access to VA facilities and systems by Contractor and Subcontractor employees and/or termination of the contract for default.
- k. PIV Credential Holders must follow all HSPD-12 policies and procedures as well as use and protect their assigned identity credentials in accordance with VA policies and procedures, displaying their badges at all times, and returning the identity credentials upon termination of their relationship with VA.

Deliverable:

- A. Contractor Staff Roster

6.3 METHOD AND DISTRIBUTION OF DELIVERABLES

The Contractor shall deliver documentation in electronic format, unless otherwise directed in Section B of the solicitation/contract. Acceptable electronic media include: Microsoft 365 suite, MS Word, MS Excel, MS PowerPoint, MS Project, MS Access, MS Visio, AutoCAD, and Adobe Postscript Data Format (PDF).

6.4 PERFORMANCE METRICS

The table below defines the Performance Standards and Acceptable Levels of Performance associated with this effort.

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

Performance Objective	Performance Standard	Acceptable Levels of Performance
A. Technical / Quality of Product or Service	1. Demonstrates understanding of requirements 2. Efficient and effective in meeting requirements 3. Meets technical needs and mission requirements 4. Provides quality services/products 5. Incorporates "ease of use" Human Centered Design principles in any software developed.	Satisfactory or higher
B. Project Milestones and Schedule	1. Established milestones and project dates are met 2. Products completed, reviewed, delivered in accordance with the established schedule 3. Notifies customer in advance of potential problems	Satisfactory or higher
C. Cost & Staffing	1. Currency of expertise and staffing levels appropriate to perform tasks required 2. Personnel possess necessary knowledge, skills, and abilities to perform tasks	Satisfactory or higher
D. Management	1. Integration and coordination of all activities to execute effort	Satisfactory or higher

The COR will utilize a Quality Assurance Surveillance Plan (QASP) throughout the life of the contract to ensure that the Contractor is performing the services required by this PWS in an acceptable level of performance. The Government reserves the right to alter or change the surveillance methods in the QASP at its own discretion. A Performance Based Service Assessment will be used by the COR in accordance with the QASP to assess Contractor performance.

ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED

A1.0 Cyber and Information Security Requirements for VA IT Services

The Contractor shall ensure adequate LAN/Internet, data, information, and system security in accordance with VA standard operating procedures and standard PWS language, conditions, laws, and regulations. The Contractor's firewall and web server shall meet or exceed VA minimum requirements for security. All VA data shall be protected behind an approved firewall. Any security violations or attempted violations shall be reported to the VA Program Manager and VA Information Security Officer as soon as possible. The Contractor shall follow all applicable VA policies and procedures governing information security, especially those that pertain to assessment and authorization and continuous monitoring.

Contractor supplied equipment, PCs of all types, equipment with hard drives, etc. for contract services must meet all security requirements that apply to Government Furnished Equipment (GFE) and Government Owned Equipment (GOE). Security Requirements include: a) VA Approved Encryption Software must be installed on all laptops or mobile devices before being placed into operation, b) Bluetooth equipped devices are prohibited within VA; Bluetooth must be permanently disabled or removed from the device, unless the connection uses FIPS 140-2 (or its successor) validated encryption, c) VA approved anti-virus and firewall software, d) Equipment must meet all VA sanitization requirements and procedures before disposal. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems.

Each documented initiative under this contract incorporates VA Handbook 6500.6, "Contract Security," March 12, 2010 (Appendix C updated April 22, 2024) by reference as though fully set forth therein. The VA Handbook 6500.6, "Contract Security" shall also be included in every related agreement, contract, or order. The VA Handbook 6500.6, Appendix C, is included in this document as Addendum B.

Training requirements: The Contractor shall complete all mandatory training courses on the current VA training site, the VA Talent Management System (TMS) 2.0, and will be tracked therein. The TMS 2.0 may be accessed at <https://www.tms.va.gov/SecureAuth35/>. If you do not have a TMS 2.0 profile, go to <https://www.tms.va.gov/SecureAuth35/> and click on the "Create New User" link on the TMS 2.0 to gain access.

Contractor employees shall complete a VA Systems Access Agreement if they are provided access privileges as an authorized user of the computer system of VA.

A2.0 VA Enterprise Architecture Compliance

The applications, supplies, and services furnished under this contract must comply with VA Enterprise Architecture (EA), available at <http://www.ea.oit.va.gov/index.asp> in force at the time of issuance of this contract, including the Program Management Plan and

VA's rules, standards, and guidelines in the Technical Reference Model/Standards Profile (TRMSP). VA reserves the right to assess contract deliverables for EA compliance prior to acceptance.

A2.1. VA Internet and Intranet Standards

The Contractor shall adhere to and comply with VA Directive 6102 and VA's Web Governance if the Contractor's work includes building and maintaining VA's digital presence. This pertains, but is not limited to: websites, social media, creating announcements; collecting information; databases to be accessed, graphics and links to external sites.

Internet/Intranet Services Directive 6102 is posted at (copy and paste the following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1056&FType=2

VA Web Governance website can be found at [Home - VA Web Governance](#).

A3.0 Notice of the Federal Accessibility Law Affecting All Information and Communication Technology (ICT) Procurements (Section 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

A3.1. Section 508 – Information and Communication Technology (ICT) Standards

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255 Guidelines \(access-board.gov\)](#). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request, or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with "508 Chapter 2: Scoping Requirements" for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☒ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

A3.2. Compatibility with Assistive Technology

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

A3.3. Acceptance and Acceptance Testing

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

A4.0 Physical Security & Safety Requirements:

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for persons violating the law.

1. The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
2. VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the Contractor to park in the appropriate designated parking areas. VA will not invalidate or make reimbursement for parking violations of the Contractor under any conditions.
3. Smoking is prohibited inside/outside any building other than the designated smoking areas.
4. Possession of weapons is prohibited.
5. The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or vendor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary

to protect persons and property from injury or damage during the performance of this contract.

A5.0 Confidentiality and Non-Disclosure

The Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations.

The Contractor may have access to Protected Health Information (PHI) and Electronic Protected Health Information (ePHI) that is subject to protection under the regulations issued by the Department of Health and Human Services, as mandated by the Health Insurance Portability and Accountability Act of 1996 (HIPAA); 45 CFR Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 CFR Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"). Pursuant to the Privacy and Security Rules, the Contractor must agree in writing to certain mandatory provisions regarding the use and disclosure of PHI and ePHI.

1. The Contractor will have access to some privileged and confidential materials of VA. These printed and electronic documents are for internal use only, are not to be copied or released without permission, and remain the sole property of VA. Some of these materials are protected by the Privacy Act of 1974 (revised by PL 93-5791) and Title 38. Unauthorized disclosure of Privacy Act or Title 38 covered materials is a criminal offense.
2. The VA CO will be the sole authorized official to release in writing, any data, draft deliverables, final deliverables, or any other written or printed materials pertaining to this contract. The Contractor shall release no information. Any request for information relating to this contract presented to the Contractor shall be submitted to the VA CO for response.
3. Contractor personnel recognize that in the performance of this effort, Contractor personnel may receive or have access to sensitive information, including information provided on a proprietary basis by carriers, equipment manufacturers and other private or public entities. Contractor personnel agree to safeguard such information and use the information exclusively in the performance of this contract. Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations as enumerated in this section and elsewhere in this Contract and its subparts and appendices.
4. Contractor shall limit access to the minimum number of personnel necessary for contract performance for all information considered sensitive or proprietary in nature. If the Contractor is uncertain of the sensitivity of any information obtained during the performance this contract, the Contractor has a responsibility to ask the VA CO.
5. Contractor shall train all of their employees involved in the performance of this contract on their roles and responsibilities for proper handling and nondisclosure of sensitive VA or proprietary information. Contractor personnel shall not engage in any other action, venture or employment wherein sensitive information shall be used for the profit of any party other

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

than those furnishing the information. The sensitive information transferred, generated, transmitted, or stored herein is for VA benefit and ownership alone.

6. Contractor shall maintain physical security at all facilities housing the activities performed under this contract, including any Contractor facilities according to VA-approved guidelines and directives. The Contractor shall ensure that security procedures are defined and enforced to ensure all personnel who are provided access to patient data must comply with published procedures to protect the privacy and confidentiality of such information as required by VA.
7. Contractor must adhere to the following:
 - a. The use of "thumb drives" or any other medium for transport of information is expressly prohibited.
 - b. Controlled access to system and security software and documentation.
 - c. Recording, monitoring, and control of passwords and privileges.
 - d. All terminated personnel are denied physical and electronic access to all data, program listings, data processing equipment and systems.
 - e. VA, as well as any Contractor (or Subcontractor) systems used to support development, provide the capability to cancel immediately all access privileges and authorizations upon employee termination.
 - f. Contractor PM and VA PM are informed within twenty-four (24) hours of any employee termination.
 - g. Acquisition sensitive information shall be marked "Acquisition Sensitive" and shall be handled as "For Official Use Only (FOUO)".
 - h. Contractor does not require access to classified data.
8. Regulatory standard of conduct governs all personnel directly and indirectly involved in procurements. All personnel engaged in procurement and related activities shall conduct business in a manner above reproach and, except as authorized by statute or regulation, with complete impartiality and with preferential treatment for none. The general rule is to strictly avoid any conflict of interest or even the appearance of a conflict of interest in VA/Contractor relationships.
9. VA Form 0752 shall be completed by all Contractor employees working on this contract and shall be provided to the CO before any work is performed. In the case that Contractor personnel are replaced in the future, their replacements shall complete VA Form 0752 prior to beginning work.

ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE

NOTE: In the event of a conflict, VAAR Security Clauses take precedence over the language in this Addendum B.

APPLICABLE SECTIONS FROM: VA NOTICE 24-12, APRIL 22, 2024, UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B2. VA INFORMATION CUSTODIAL LANGUAGE

- a. The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General. The primary clause used to define computer software license (not data/intellectual property first produced under this Contractor or order) is FAR 52.227-19, Commercial Computer Software License.
- b. Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA Contracting Officer (CO). The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- c. VA information will not be co-mingled with any other data on the Contractor’s information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.
- d. VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support (including access to Contractor and Subcontractor staff associated with the contract) to VA, VA's Office Inspector General (OIG), and/or Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.

- e. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- f. The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.
- g. If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.
- h. The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.
- i. The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO.

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.

- k. Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.
- l. Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract will be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.
- m. Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- n. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- o. Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that is used to store, process, or access VA information that cannot be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.
- p. All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information will not be returned to the

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph will only be granted with the written approval of VA CO.

B3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

- a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees and subcontractors only to the extent necessary to perform the services specified in the solicitation or contract. This includes indirect entities, both affiliate of Contractor/Subcontractor and agent of Contractor/Subcontractor.
- b. Contractors and subcontractors shall sign the VA Information Security Rule of Behavior (ROB) before access is provided to VA information and information systems (see Section 4, Training, below). The ROB contains the minimum user compliance requirements and does not supersede any policies of VA facilities or other agency components which provide higher levels of protection to VA's information or information systems. Users who require privileged access shall complete the VA elevated privilege access request processes before privileged access is granted.
- c. All Contractors and Subcontractors working with VA information are subject to the same security investigative and clearance requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors shall be in accordance with VA Directive and Handbook 0710, Personnel Suitability and Security Program. The Office of Human Resources and Administration/Operations, Security and Preparedness (HRA/OSP) is responsible for these policies and procedures. Contract personnel who require access to classified information or information systems shall have an appropriate security clearance. Verification of a Security Clearance shall be processed through the Special Security Officer located in HRA/OSP. Contractors shall conform to all requirements stated in the National Industrial Security Program Operating Manual (NISPOM).
- d. All Contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All Contractors and Subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the Contractor must state where all non-U.S. services are provided. The Contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted.

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

- e. The Contractor shall notify the COR/CO in writing immediately (no later than 24 hours) after personnel separation or occurrence of other causes. Causes may include the following:
 - (1) Contractor/Subcontractor personnel no longer has a need for access to VA information or VA information systems.
 - (2) Contractor/Subcontractor personnel are terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.
 - (3) Contractor believes their own personnel or Subcontractor personnel may pose a threat to their company's working environment or to any company-owned property. This includes Contractor-owned assets, buildings, confidential data, customers, employees, networks, systems, trade secrets and/or VA data.
 - (4) Any previously undisclosed changes to Contractor/Subcontractor background history are brought to light, including but not limited to changes to background investigation or employee record.
 - (5) Contractor/Subcontractor personnel have their authorization to work in the United States revoked.
 - (6) Agreement by which Contractor provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and/or physical access for Contractor personnel.
- f. In such cases of contract fulfillment, termination, or other causes; the Contractor shall take the necessary measures to immediately revoke access to VA network, property, information, and information systems (logical and physical) by Contractor/Subcontractor personnel. These measures include (but are not limited to): removing and then securing Personal Identity Verification (PIV) badges and PIV – Interoperable (PIV-I) access badges, VA-issued photo badges, credentials for VA facilities and devices, VA-issued laptops, and authentication tokens. Contractors shall notify the appropriate VA COR/CO immediately to initiate access removal.
- g. Contractors/Subcontractors who no longer require VA accesses will return VA-issued property to VA. This property includes (but is not limited to): documents, electronic equipment, keys, and parking passes. PIV and PIV-I access badges shall be returned to the nearest VA PIV Badge Issuance Office. Once they have had access to VA information, information systems, networks and VA property in their possessions removed, Contractors shall notify the appropriate VA COR/CO.

B4. TRAINING

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

- a. All contractors and subcontractors requiring access to VA information and VA information systems shall successfully complete the following before being granted access to VA information and its systems:
 - (1) VA Privacy and Information Security Awareness and Rules of Behavior course (Talent Management System (TMS) #10176) initially and annually thereafter.
 - (2) Sign and acknowledge (electronically through TMS #10176) understanding of and responsibilities for compliance with the Organizational Rules of Behavior, relating to access to VA information and information systems initially and annually thereafter; and
 - (3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system or information access [to be defined by the VA program official and provided to the VA CO for inclusion in the solicitation document – i.e., any role-based information security training].
- b. The Contractor shall provide to the COR/CO a copy of the training certificates and certification of signing the Organizational Rules of Behavior for each applicable employee within five days of the initiation of the contract and annually thereafter, as required.
- c. Failure to complete the mandatory annual training is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the required training is complete.

B5. SECURITY INCIDENT INVESTIGATION

- a. The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

- (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).
 - (5) The amount of data belonging to VA believed to have been compromised.
 - (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
- c. After the Contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
 - d. VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.
 - e. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.
 - f. The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
 - g. With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
 - h. If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach

involving any VA sensitive personal information the Contractor/Subcontractor processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause 852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs.

B6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

N/A

B7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

- a. The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. The controls will be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.
- b. Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- c. The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.
- d. All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).

- e. Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR/CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.
- f. All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate (ATO) documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.
- g. The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third-party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- h. VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall on the non-VA owned OE. Approved Contractor OE will be subject to technical inspection at any time.
- i. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected

component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues will be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.

- j. For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation will include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.
- k. All other vulnerabilities, including those discovered through routine scans or other assessments, will be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency (CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph will only be granted with the approval of the COR/CO.

B8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING

- a. Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the information security, network or system requirements mandated in the agreement between VA and the Contractor.
- b. Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out will commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree will not unduly impact Contractor operations; (b):

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.

- c. As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.
- d. The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any such security reports or other related assessments, upon completion and validation.
- e. VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B9. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

- a. The Contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- b. When contracting terms require the Contractor to procure equipment, the Contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The Contractor shall attest that equipment procured from an OEM or authorized reseller or distributor are authentic. If procurement is unavailable from an OEM or authorized reseller, the Contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.
- c. All Contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation will

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The Contractor shall make spare parts available. All Contractor(s) shall specify how digital delivery for procured products, including patches, will be validated and monitored to ensure consistent delivery. The Contractor shall apply encryption technology to protect procured products throughout the delivery process.

- d. If a Contractor provides software or patches to VA, the Contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- e. The Contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the data formats defined in the National Telecommunications and Information Administration (NTIA) report "The Minimum Elements for a Software Bill of Materials (SBOM)."
- f. Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- g. Throughout the delivery process, the Contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- h. The Contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.

B10. VIRUSES, FIRMWARE, AND MALWARE

- a. The Contractor shall execute due diligence to ensure all provided software and patches, including third-party patches, are free of viruses and/or malware before releasing them to or installing them on VA information systems.
- b. The Contractor warrants it has no knowledge of and did not insert, any malicious virus and/or malware code into any software or patches provided to VA which could potentially harm or disrupt VA information systems. The Contractor shall use due diligence, if supplying third-party software or patches, to ensure the third-party has not inserted any malicious code and/or virus which could damage or disrupt VA information systems.
- c. The Contractor shall provide or arrange for the provision of technical justification as to why any "false positive" hit has taken place to ensure their code's supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus vendor.

- d. The Contractor shall not upload (intentionally or negligently) any virus, worm, malware or any harmful or malicious content, component and/or corrupted data/source code (hereinafter "virus or other malware") onto VA computer and information systems and/or networks. If introduced (and this clause is violated), upon written request from the VA CO, the Contractor shall:
 - (1) Take all necessary action to correct the incident, to include any and all assistance to VA to eliminate the virus or other malware throughout VA's information networks, computer systems and information systems; and
 - (2) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

B11. CRYPTOGRAPHIC REQUIREMENT

- a. The Contractor shall document how the cryptographic system supporting the Contractor's products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- b. The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- c. The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- d. The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.
- e. The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B12. PATCHING GOVERNANCE

- a. The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-party) prior to the connection of electronic devices, assets or equipment to VA's assets. This documentation will include information regarding the following:

Integrated eNotifications Service Pilot via Direct Secure Messaging
VA-26-00049664

- (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- b. The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.
 - c. The Contractor shall provide or arrange the provision of appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses for their products and services within 30 days of discovery. Updates to remediate critical or emergent vulnerabilities will be provided within seven business days of discovery. If updates cannot be made available by Contractor within these time periods, the Contractor shall submit mitigations, methods of exploit detection and/or workarounds to the COR/CO prior to the above deadlines.
 - d. The Contractor shall provide or arrange for the provision of appropriate hardware, software and/or firmware updates, when those products, including open-source software, are provided to the VA, to remediate newly discovered vulnerabilities or weaknesses. Remediations of products or services provided to the VA's system environment must be provided within 30 business days of availability from the original supplier and/or patching source. Updates to remediate critical vulnerabilities applicable to the Contractor's use of the third-party product in its system environment will be provided within seven business days of availability from the original supplier and/or patching source. If applicable third-party updates cannot be integrated, tested and made available by Contractor within these time periods, mitigations and/or workarounds will be provided to the COR/CO before the above deadlines.

B13. SPECIALIZED DEVICES/SYSTEMS (MEDICAL DEVICES, SPECIAL PURPOSE SYSTEMS, RESEARCH SCIENTIFIC COMPUTING)

N/A

B14. DATA CENTER PROVISIONS

N/A